

SCREENING STANDARD

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Screening Standard
Document ID	STD-SCR-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Standard is authorised by the Human Resources Security Policy (POL-HRS-001) and supports the SOC 2 Trust Services Criteria CC1.1, CC1.4 and CC9.2, and HIPAA Security Rule 45 CFR §164.308(a)(3). It applies only so far as the checks it requires are lawful and customary in the jurisdiction in which each person works.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 Overview and Purpose

This Standard defines the screening the Company carries out before anyone is given access, and the record it keeps. It exists so that the phrase “the tier applied” in the Human Resources Security Policy and the Access Control Policy points at something definite.

PromptHalo Technologies (“the Company”) is a small, distributed team in which almost everyone is engaged part-time or through a contract for services. The Company operates a single screening tier and will continue to do so until it reaches 50 personnel. One tier, applied consistently and recorded, is stronger evidence than several tiers applied unevenly.

2 Scope

This Standard applies to every person who will hold Company or client access, whether employee, officer, contractor, consultant, intern or temporary worker, and to any engaging firm that screens on the Company's behalf.

Screening is carried out only to the extent lawful and customary where the person works. Where a check named below is unlawful, restricted or disproportionate in that jurisdiction, the next lawful equivalent is used, and the reason is noted on the screening record. That is a complete result, not an exception.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this Standard, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this Standard and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party carries out or accepts the screening, holds the screening records, and records any substitution made for local law. At the Company's current size there is no separate approval step. [SOC 2: CC1.3, CC1.2]

4 Terminology

The following terms have the meanings given below wherever they appear in this Standard.

1. **Engaging firm** — a company that supplies a contractor or consultant to the Company under a contract for services.
2. **Right to work** — confirmation that the person may lawfully perform the work in the place where they will perform it.
3. **Screening record** — the dated entry showing what was confirmed, by whom and when, held for each person.

4. **Tier** — the set of checks that applies to a person. The Company operates one tier, described in Section 5.

5 The Single Screening Tier

One tier applies to everyone, whatever their role or level of access. It has two parts, both documented, and together they take a few minutes per person.

1. Identity is confirmed from a government-issued photographic document, viewed directly or over video. [SOC 2: CC1.1 • HIPAA §164.308(a)(3)]
2. Right to work in the place where the work will be performed is confirmed from the document the person relies on. [SOC 2: CC1.1, CC1.4]
3. Both are viewed and confirmed rather than copied and stored, except where retention of a copy is required by law. [SOC 2: CC6.5 • GDPR Art. 5(1)(c)]
4. No criminal record check, credit check, adverse media search or paid screening service is required at the Company's current size, and none is carried out unless a client agreement expressly requires it. Where one does, the cost and the requirement are treated as part of that engagement. [SOC 2: CC1.4, CC9.2]
5. A signed confidentiality and intellectual property agreement is required before access under the Human Resources Security Policy. It is not a substitute for the confirmations above: an agreement records what someone has undertaken, whereas screening records who they are. Both are needed, and the agreement is not recorded here. [SOC 2: CC1.1, CC1.5]

6 Timing and Gating

1. Screening is completed and recorded before access is granted. Access is not set up in AWS, GitHub or Google Workspace until the screening record exists. [SOC 2: CC1.4, CC6.2 • HIPAA §164.308(a)(3)]
2. Where an engagement must begin before a confirmation is obtained, that is noted on the screening record with a date by which it will be obtained, and access is withdrawn if it is not. No separate exception form is needed. [SOC 2: CC1.4, CC5.3]
3. Because one tier applies to everyone, no re-screening is required when a person's access changes. [SOC 2: CC6.3]

7 Contractors and Engaging Firms

1. Where a contractor is engaged through a firm, that firm's written confirmation that it has confirmed the person's identity and right to work is retained in place of the underlying records. The Company does not ask to see the firm's source documents. An email is sufficient. [SOC 2: CC1.4, CC9.2]
2. The confirmation names the person, states what was confirmed and the date. It is obtained once at the start of the engagement and is not repeated at renewal unless the person changes. [SOC 2: CC9.2]

3. Where no firm is involved, the person is screened directly under Section 5. [SOC 2: CC1.4]

8 Records and Retention

1. The screening record shows the person, what was confirmed, any substitution made for local law and its reason, who confirmed it and the date. Two lines on the personnel list is sufficient; no separate system is required. [SOC 2: CC1.1, CC1.4 • GDPR Art. 5(1)(c)]
2. Screening records are held with the personnel records, restricted to the Accountable Party, and retained for the duration of the engagement and for one year afterwards unless a longer period is required by law. [SOC 2: CC6.1 • GDPR Art. 5(1)(e)]

9 When This Standard Changes

The single tier holds until the Company reaches 50 personnel. At that point, or earlier if a client agreement or applicable regulation requires deeper checks for a particular role, the Accountable Party introduces additional tiers and this Standard is reissued.

1. Headcount is checked against this threshold at the annual review recorded in the Annual Control Environment Assessment. Where the threshold has not been reached, that is recorded and the single tier continues. [SOC 2: CC1.4, CC4.1]

10 Exceptions

A departure from this Standard is recorded by the Accountable Party before access is granted, with the reason, what was done instead and a date for review, and is reviewed at the annual policy review. Where no departures are in force, that is recorded affirmatively at that review. A line in the screening record is sufficient; no separate register is required.

11 Reference

1. SOC 2 Trust Services Criteria, Security category [CC1.1, CC1.4, CC6.1, CC6.2, CC9.2]
2. POL-HRS-001 Human Resources Security Policy [SOC 2: CC1.4]
3. POL-AC-001 Access Control Policy [SOC 2: CC6.1, CC6.2]
4. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
5. FRM-CE-001 Annual Control Environment Assessment [SOC 2: CC4.1]
6. HIPAA Security Rule, 45 CFR §164.308(a)(3)
7. EU General Data Protection Regulation, Articles 5 and 6
- 8.

1 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	August 18, 2026	Initial policy release

99